



Lab 16 — Capstone — Build the AI Security Governance Roadmap

Topic 04: Security Controls for Agentic AI, Risk Assessment and Implementation Roadmap

Objective: Implement a prioritised, costed and sequenced AI security governance implementation roadmap and present it for executive approval.

Goal: The capstone brings the whole course together. You will consolidate every artefact you have produced into a 12-month AI security governance implementation roadmap for NovaBank, sequenced by risk reduction per unit of effort, with metrics that prove the programme is working — then present it for approval.

What you'll build: A 12-month AI security governance roadmap across three phases with initiatives, owners, effort, dependencies and success metrics, plus a five-slide executive presentation.

Tools and data: Roadmap template, maturity model, all prior lab outputs, presentation template

Data files in this lab

- data/exec-presentation-template.md
- data/maturity-model.md
- data/roadmap-template.csv

Step-by-step

1. Consolidate your inputs: the Lab 5 gap register, the Lab 15 risk assessment, the Lab 6 policy set, the Lab 7 operating model, the Lab 13 control stack and the Lab 14 agentic registry.
2. Assess current maturity across five domains — governance structure, policy, inventory and risk, lifecycle controls, and agentic controls — scoring each 1 to 5 with the evidence behind the score.
3. Set the 12-month target maturity per domain. Targeting level 5 everywhere is not a plan; choose where NovaBank genuinely needs to be and say why.
4. Build Phase 1 (months 1-3), the foundation: complete the AI inventory with owners, issue the acceptable-use policy, stand up the governance committee and turn on logging. These are cheap, fast and close the widest gaps.

5. Build Phase 2 (months 4-8), the controls: risk assessment for every High-tier system, deployment gates, the agentic control stack for NovaAssist, monitoring with thresholds, and the incident playbooks.
6. Build Phase 3 (months 9-12), the assurance: red-teaming as routine, third-party AI assurance, independent review, metrics reporting to the board and the first full re-assessment cycle.
7. For every initiative record owner, effort (S/M/L), dependencies and the specific gap or risk it closes. An initiative that closes nothing from your registers should be cut.
8. Sequence by risk reduction per unit of effort and resolve the dependencies — you cannot risk-assess systems you have not inventoried, and you cannot enforce a policy you have not issued.
9. Define six programme metrics with baselines and 12-month targets: inventory coverage, percentage of High-risk systems assessed, policy attestation rate, time to disable an agent, AI incidents and mean time to respond.
10. Build the five-slide executive presentation: where we are, what could go wrong, what we will do, what it costs, and what you are approving. Present in five minutes and defend one challenge from the trainer as board chair.

Test it

Every initiative in your roadmap traces back to a specific gap or a specific rated risk, the phases respect their dependencies, and all six metrics have a baseline and a target. Your five-slide deck makes the ask explicit on the final slide.

Training use only. The organisation, data and individuals in this lab are fictional. Security techniques taught here must only be applied to systems you own or have written authorisation to test.